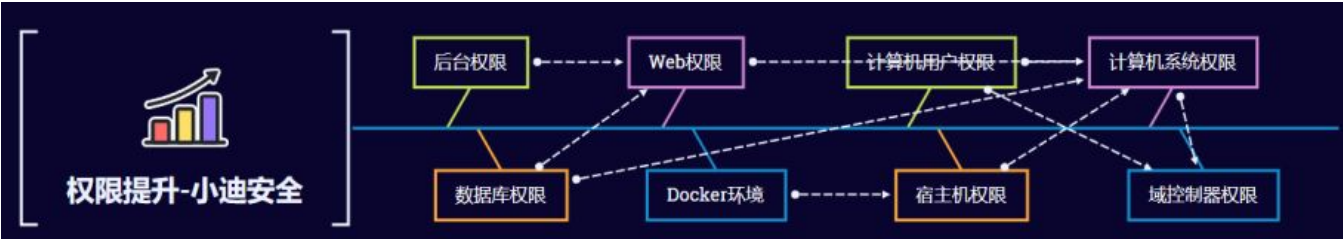


Day131 权限提升-Web权限提升篇&划分获取&资产服务&后台系统&数据库管理&相互转移



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 1 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

3.演示案例

3.1 权限提升-Web应用&中间件&数据库



- 1 背景1: 通过弱口令进入web后台系统通过上传获取web权限
- 2 背景2: 通过Tomcat弱口令进入控制界面通过上传获取web权限
- 3 背景3: 通过Redis未授权进入管理端通过SQL执行获取web权限

3.2 权限转移-后台管理&数据库管理&Web



- 1 Tmall-后台权限->web权限（提升）
- 2 Tmall-web权限->数据库权限（转移）
- 3 Tmall-web权限->另一个后台权限（转移）
- 4
- 5 PhpMyadmin-数据管理->web权限（提升）
- 6 PhpMyadmin-web权限->另一个后台权限（转移）